

Public Key Cryptography

Kavinga Yapa Abeywardena

AGENDA

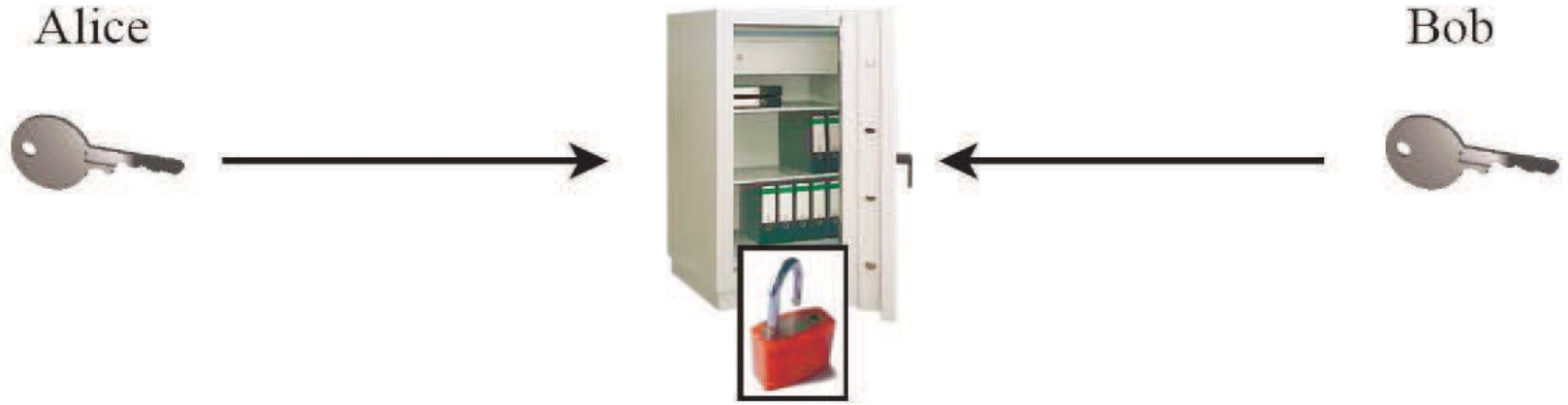
- Symmetric Cryptography Revisited
- Principles of Asymmetric Cryptography
- Public-Key Cryptography : Limitations
- Hybrid Cryptography
- Digital Signatures
- Certificates & PKI

Symmetric Cryptography Revisited

- Same **secret key** ***K*** is used for encryption and decryption



Symmetric Cryptography - Limitations



- Safe with a **STRONG** lock
- Only Alice and Bob should have the key
- **Key distribution problem**: Secret key must be transported securely
- Another problem?

Public Key Cryptography (Asymmetric)

- New idea proposed in 1976 by Whitfield **Diffie** and Martin **Hellman**.



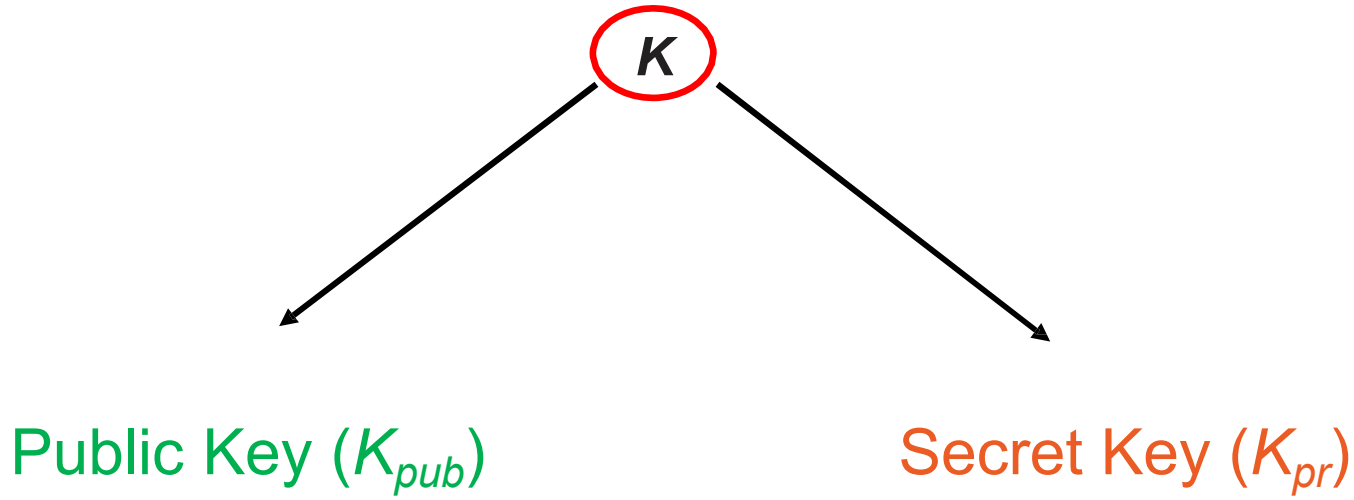


Everyone can drop a letter

Only the owner has the correct key to open the box

Public Key Cryptography

- **Principle:** Split up the key.
- During the key generation, a key pair K_{pub} and K_{pr} is computed



Public Key Cryptography

Alice

Bob



$(K_{pubB}, K_{prB}) = K$



Public Key Cryptography : Limitation

- 1000 times **SLOWER** than Symmetric Encryption!
- Can only encrypt a small amount of data

Solution : A Hybrid system

- Use both asymmetric and symmetric algorithms
- **Key Exchange** (for symmetric) using Public Key Encryption
- **Encryption of Messages** (faster) using Symmetric Encryption

A Hybrid Protocol : Key Exchange

Alice

Bob



$(K_{pubB}, K_{prB}) = K$



Key distribution problem Solved!

A Hybrid Protocol : Encryption of Messages



How to build a Public Key Algorithm?

Asymmetric schemes are based on a '**one-way function**'

- Computing $y = f(x)$ is computationally easy
- Computing $x = f^{-1}(y)$ is computationally infeasible

One way functions are based on **mathematically hard problems**.

Three main families:

- **Factoring integers** (RSA, ...):
  Given a composite integer *n*, find its prime factors (Multiply two primes: easy)

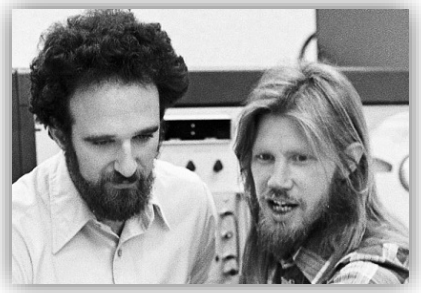
- **Discrete Logarithm** (Diffie-Hellman, Elgamal, DSA, …): Given *a, y* and *m,* find *x* such that $a^x = y \bmod m$
  (Exponentiation a^x : easy)

- **Elliptic Curves (EC)** (ECDH, ECDSA): Generalization of discrete logarithm Note: The problems are considered mathematically hard, but no proof exists (so far).

The RSA Cryptosystem

- Martin Hellman and Whitfield Diffie published their landmark public- key paper in 1976
- Ronald Rivest, Adi Shamir and Leonard Adleman proposed the asymmetric RSA cryptosystem in1977
- Until now, RSA is the most widely use asymmetric cryptosystem although elliptic curve cryptography (ECC) becomes increasingly popular (Faster)
- RSA is mainly used for two applications
  - Transport of (i.e., symmetric) keys
  - Digital signatures

Diffie–Hellman Key Exchange



- Proposed in 1976 by **Whitfield Diffie and Martin Hellman**
- **Widely used**, e.g. in Secure Shell (SSH), Transport Layer Security (TLS), and Internet Protocol Security (IPSec)
- The Diffie–Hellman Key Exchange (DHKE) is a key exchange protocol and **not** used for encryption

  (For the purpose of encryption based on the DHKE, ElGamal can be used.)





Digital Signatures



Motivation for Digital Signatures

- Alice orders a pink car from the car salesmen Bob
- After seeing the pink car, Alice states that she has never ordered it:

- How can Bob prove towards a judge that Alice has ordered a pink car? (And that he did not fabricate the order himself)

$\Rightarrow$ Symmetric cryptography fails because both Alice and Bob can be malicious

$\Rightarrow$ Can be achieved with public-key cryptography

Digital Signatures : Basic Principle



Digital Signatures

- For a given message '***x'***, a digital signature is appended to the message (just like a conventional signature).
- Only the **person with the private key** should be able to **generate** the signature.
- The signature must change for every document.

⇒The signature is realized as a function with the message ***'x'*** and the private key as input.

⇒The public key and the message ***'x'*** are the inputs to the verification function.

CERTIFICATES

- In order to authenticate public keys, all public keys are digitally signed by a central trusted authority.
- Such a construction is called *certificate*

certificate = public key + ID(user) + digital signature over public key and ID

- In its most basic form, a certificate for the key k_{pub} of user Alice is:

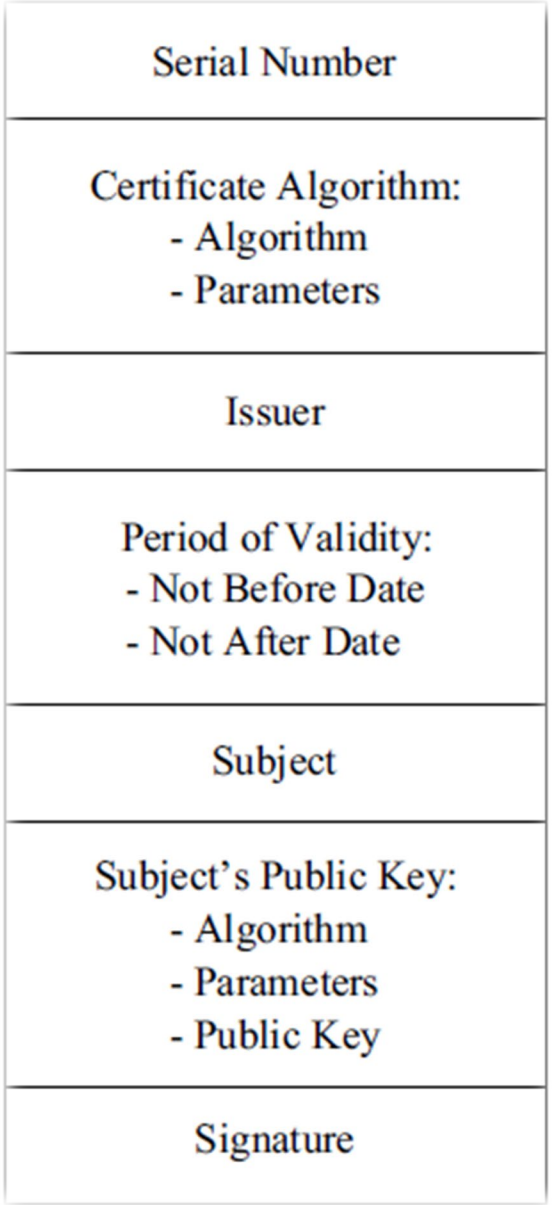
$$\mathbf{Cert(Alice) = (}k_{pub}\mathbf{,\ ID(Alice),\ }sig_{KCA}(k_{pub}\mathbf{,ID(Alice)\ )}$$

- Certificates bind the identity of user to his/her public key
- The trusted authority that issues the certificate is referred to as ***certifying authority (CA)***
- "Issuing certificates“ means in particular that the CA computes the signature $sig_{KCA}(k_{pub})$ using its **(super secret!)** private key k_{CA}

- The party who receives a certificate, e.g., Bob, verifies Alice‘s public key using the public key of the CA

CERTIFICATES IN REAL WORLD

- In real world certificates contain much more information than just a public key and a signature.
- **X509** is a popular signature standard. The main fields of such a certificate are shown to the right.



REMAINNING ISSUES WITH CERTIFICATES

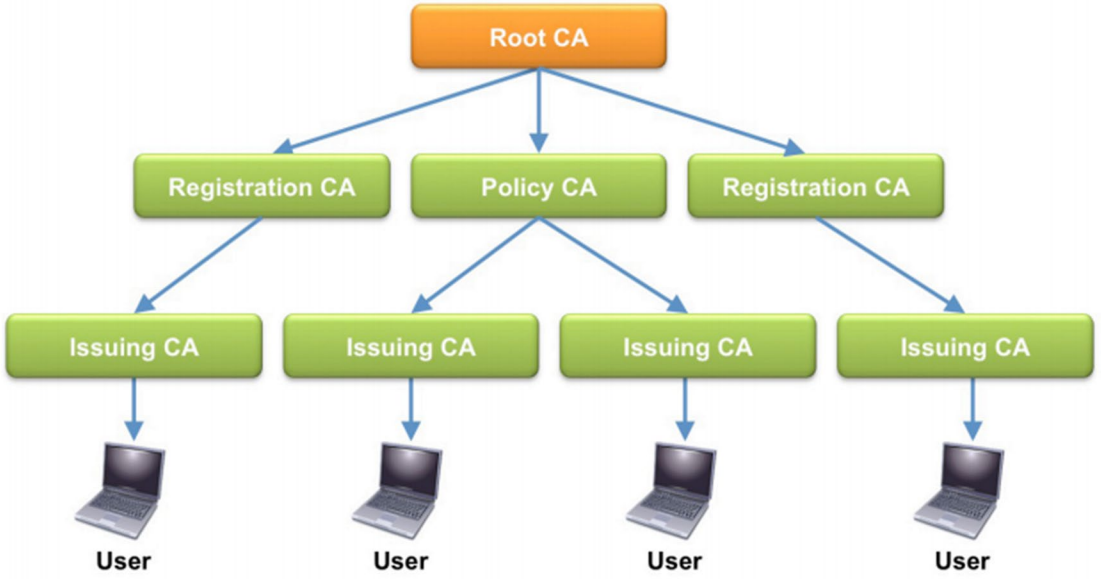
There are many additional problems when certificates are to be used in systems with a large number of participants. The more pressing ones are:

1. Users communicate which other whose certificates are issued by different CAs
   - This requires cross-certification of CAs, e.g.. CA1 certifies the public-key of CA2. If Alice trusts her CA1, cross-certification ensures that she also trusts CA2. This is called a **"chain of trust"** and it is said that trust is delegated.

2. Certificate Revocation Lists (CRLs)
   - Another real-world problem is that certificates must be revoked, e.g., if a smart card with certificate is lost or if a user leaves an organization. For this, **CRL**s must be sent out periodically (e.g., daily) which is a burden on the bandwidth of the system.

Public Key Infrastructure

The entire system that is formed by CAs together with the necessary support mechanisms is called a **public-key infrastructure (PKI).**




Thank
You